T05 · 移动端使用与安全访问 PRD

版本：1.0；日期：2026-10-10（Asia/Shanghai）；状态：需求初稿，待评审、待认领。

入口：总清单 · 交接记录 · 测试用例 · 公共边界

1. 摘要

让用户在手机浏览器中查看工作台、派发任务、追踪结果和反馈，任务仍由已配对电脑上的本机 Runner/CLI 执行。远程入口必须同时完成设备认证和安全部署，不能仅把现有服务绑定到 0.0.0.0。

2. 现状与问题

当前 Server 仅监听 127.0.0.1，人类 REST/WS 无认证；daemon/task token 不等于用户登录。界面存在固定侧栏、320px 看板列、最小宽度任务面板，尚无完整手机交互。直接开放会暴露管理接口、任务内容及本机信息。电脑休眠或 Runner 离线也不能由手机自动补成云执行。

3. 目标与指标

目标	验收标准
手机核心可用	320、390、430 CSS px 下可完成查看、派活、跟进、反馈；正文无整体横向滚动，Diff/代码允许局部滚动
访问受控	未认证无法读取任务、管理信息或建立已认证 WS；设备撤销立即阻止新请求并断开其连接
弱网可靠	超时/切后台/重连不重复派活，草稿与未知结果有恢复入口
真机证据	至少一台 iOS Safari 和一台 Android Chrome 完成核心流程，记录版本、设备、网络及结果

4. 用户、范围与非目标

首期仍是同一所有者的多设备访问，不扩展多租户/RBAC。T04 的频道线程核心稳定后实施，安全方案和响应式设计可提前。

包含响应式网页、设备配对/会话/撤销、HTTPS 私有访问部署、弱网恢复和主机状态。包含查看证据与提交返工；完整 Diff 审批/合入留在桌面及已有 GitHub 流程，手机不新增简化批准按钮。

不做原生 App、PWA 离线运行、后台推送、手机运行 CLI、唤醒关机电脑、托管云 Runner或公网匿名入口。

5. 功能需求

T05-FR01 响应式交互（P0）

- [ ] 导航变为可收起入口，频道/线程/任务详情按手机层级切换；状态和返回位置保留。
- [ ] 触控主操作至少 44×44 CSS px，适应安全区、横竖屏和软键盘；输入框/提交按钮不被遮挡。
- [ ] 320/390/430 宽度无正文整体溢出；长标题、错误信息、代码和 Diff 可阅读，状态不只靠颜色。

T05-FR02 手机核心流程（P0）

- [ ] 可选项目/线程、编辑派活草稿、核对仓库/Profile/目标后明确提交，复用 T04 命令幂等。
- [ ] 可查看进度、折叠日志、Report、验证结果、PR 链接，发送讨论或明确追加指令。
- [ ] 已排队、运行、待审、失败和需输入可辨认；切回应用不会误建第二个任务。

T05-FR03 证据与反馈（P0）

- [ ] 证据展示绑定 Task/HEAD/更新时间，旧结果和最新轮次不混淆；手机不能把未验证显示为通过。
- [ ] 返工操作绑定 expected_head 与明确文本；HEAD 变化要求刷新确认，保留历史记录。
- [ ] 复杂审查提供桌面/PR 继续入口；首期手机不新增批准/覆盖/合入操作，也不能绕过 T01 Gate。
- [ ] 服务端按会话角色禁止 mobile 直接调用既有 merge、approve、override 等批准/合入写接口；不依据 User-Agent、视口或按钮隐藏判断权限。可信电脑仍须通过 T01 Gate。

T05-FR04 配对与会话（P0）

- [ ] 由已可信的电脑端主动创建有期限、一次性、限制尝试次数的配对挑战，并明确确认新设备。
- [ ] 手机取得有有效期、可轮换/撤销的独立人类会话；只存会话凭据，不同步 CLI/GitHub/daemon 认证材料。
- [ ] 配对失败、超时、重复使用和锁定可解释；日志、URL 查询串、分析事件不泄漏挑战或会话。

T05-FR05 HTTP/WS 全面保护（P0）

- [ ] 梳理所有人类 REST、下载/导出和 WS 路由；启用远程模式后统一鉴权，未认证只保留必要登录/健康最小信息。
- [ ] Cookie 会话使用 HttpOnly/Secure/SameSite；变更请求校验 Origin/CSRF，WS 校验身份与允许来源；不信任任意转发头。
- [ ] 配对管理、token 生成、敏感本机配置等管理操作限制可信电脑会话；本机来源不能仅靠浏览器可伪造的参数判断。
- [ ] 撤销设备后立即失效，现有 WS 被断开；daemon/task 认证域保持独立，不能换取用户管理权限。
- [ ] 自然过期和会话轮换使旧凭据失效后，立即停止私有推送并关闭旧 WS；旧会话不能重连或继续收数据，不只在握手时验证。

T05-FR06 显式安全部署（P0）

- [ ] 默认继续 loopback；远程模式必须显式启用，先完成身份初始化和 HTTPS/private network 配置预检。
- [ ] 提供可复现的私有网络/VPN + HTTPS 反向代理部署说明，运行生产构建；不将 Vite dev 直接暴露为手机服务。
- [ ] 未配置安全入口时拒绝远程开放或保持 loopback；允许来源、可信代理和 host 校验有明确配置与测试。

T05-FR07 弱网与恢复（P0）

- [ ] 草稿按项目/线程保存；发送超时保留 command_id，查询已执行结果后再决定重发。
- [ ] 切后台/断线/重新认证后补齐事件和权威状态，显示最近同步时间；未确认发送不能展示为已派发。
- [ ] 不离线排队批准/合入等高影响动作；会话失效时保留非敏感草稿并引导重新配对/登录。

T05-FR08 主机与 Runtime 状态（P0）

- [ ] 区分手机网络、Server 可达、Runner 在线及 CLI 可用，显示最后心跳/同步时间。
- [ ] 主机休眠/离线时明确任务未开始或状态未知，不能宣称仍在云端执行。
- [ ] 恢复后查询真实任务状态；单独预检失败不覆盖既有任务的历史结果。

以上为手机首期完成要求。原生、推送和手机批准作为后续候选，不在本期承诺。

6. 非功能需求

限制登录/配对尝试、请求大小与会话寿命，敏感内容不进入浏览器持久缓存或日志；具体 TTL/限额在安全设计评审中确定并写用例。长日志按需加载，不让手机首屏下载整次运行。键盘、读屏、缩放 200% 可用。记录实际弱网条件及性能，不编造延迟指标。

7. 架构与边界

Server 增加 HumanSession/Device/PairingChallenge 与统一认证钩子；WS 握手及撤销由相同会话层管理。Web 复用 T04 API/命令模型并响应式布局；Runner 不变，手机不直连 CLI。部署说明明确 HTTPS 终止点与可信代理范围。

迁移须保留现有本机安装可启动，但一旦开启远程，不能遗留无认证管理旁路。认证设计及独立安全审查在开放前完成。

8. API、鉴权与错误（拟议）

操作	身份 / 输入	输出
POST /api/pairings	可信电脑；设备说明	短期挑战与过期时间（只展示一次）
POST /api/pairings/redeem	手机；challenge、device_name	等待电脑确认的 pairing_id，不直接授予管理权
POST /api/pairings/:id/confirm	可信电脑；确认目标设备	配对批准状态
POST /api/pairings/:id/finish	原手机配对上下文	设置安全会话 Cookie；返回 device_id/期限
GET /api/session、POST /api/session/logout	人类会话	当前权限 / 撤销当前会话
GET /api/devices、DELETE /api/devices/:id	可信电脑	设备列表 / 撤销结果

兑换请求例：{"challenge":"<一次性值>","device_name":"我的手机"}；响应例：{"pairing_id":"pair-1","state":"awaiting_confirmation","expires_at":"<时间>"}。finish 必须证明持有兑换时生成的同一浏览器短期上下文，不能仅凭 pairing_id 领取他人会话。

未认证 401、身份不足/来源不符 403、已用/过期挑战 410、限速 429；错误不泄漏账户或内部路径。任何 session/challenge 值均为敏感数据，示例不放真实值。现有 task/daemon API 维持自己的认证，不能受

Cookie 覆盖。

9. 数据模型（拟议）

类型	字段与约束
Device	id:string、label:string、role:trusted_host/mobile、created_at、last_seen_at、revoked_at?
HumanSession	id、device_id、token_hash、expires_at、rotated_at?、revoked_at?；不存明文 token
PairingChallenge	id、challenge_hash、expires_at、attempt_count、redeemer_context_hash?、confirmed_at?、consumed_at?；一次消费原子化

手机号、通讯录等不需要采集。草稿只存必要文本和项目/线程键，提供清除入口；会话密钥不写 localStorage。Web/WS 撤销依据会话/设备 ID 索引。

10. 交互与状态

电脑开启并预检安全访问 → 创建配对 → 手机输入/扫描一次性信息 → 电脑核对并确认 → 手机进入线程列表。配对、安全配置与设备管理清楚说明当前状态，不把内部 token 暴露给手机用户。

正常使用为列表、线程、详情逐层导航；离线/同步中/主机离线分别提示，草稿恢复可见，结果未知提供“查询发送结果”。

11. 集成与部署选择

复用 T04 幂等命令和断线恢复，T01 固定证据/返工契约，T02 Runtime 能力。私有访问产品选型在认领时确定，以可审查配置/真实设备连通性为证据，不为本期引入云账号系统。HTTPS 和认证为远程可用前置，不以“仅自己使用”跳过。

12. 边界情况

场景	必须行为
猜测、重放或同时兑换挑战	限速、一次消费，电脑确认正确设备
设备撤销时 WS 在线	主动断开，REST 后续请求 401/403
恶意 Origin、CSRF、伪造代理头	被拒绝，不发生任务或管理写入
点派发后锁屏/掉线	恢复查询同一命令，不重复执行
主机休眠、Server 可达但 Runner 离线	分别显示，保留任务排队/未知真实状态
旧验证过期、目标 HEAD 变化	明示需重新确认，不在手机简化批准

13. 测试与完成标准

测试用例必须含路由权限矩阵、WS/撤销、CSRF/Origin/代理、配对重放、响应式/读屏和弱网。自动化视口模拟不替代真机：iOS Safari、Android Chrome 各记录完整核心流程；无法获得设备时明确“ 真机未验收 ”，不能标完成。

全部首期 FR、产品测试/build/四包类型检查、独立安全审查和产品真机验收通过后才可交付远程模式。首期手机审批未实现是明确范围，不伪称全桌面功能覆盖。

14. 实施顺序与交接

先清点 HTTP/WS/管理接口与部署边界，评审认证/配对和撤销；完成服务端测试后做响应式与弱网，再在隔离试验环境跑真机、最后写部署/回滚说明。关闭远程模式应恢复 loopback 并使相关会话失效。

认领时确定访问方案、初始化可信电脑办法、TTL/限额、测试设备、审查者；记录所有未覆盖设备与网络环境。

15. 版本记录

版本	日期	变化	状态
1.0	2026-10-10	独立手机 PRD，包含认证/部署；核心查看派活返工，不含手机批准	初稿，未认领、未实施